M0:

Gestión acadèmica universitaria

Núria Salas, Yansul y Sara Fíguls

Índice

1. Resumen 3
2. Reparto del trabajo 4
3. Desarrollo 4
3.1. Presentación del caso de negocio 4
3.2. Diseño del modelo entidad-relación (E-R) 5
3.3. Creación del esquema de la base de datos MySQL 6
3.4. Despliegue del entorno con Docker Compose 7
3.5. Generación y carga de datos sintéticos 7
3.6. Clasificación de los datos según el nivel de sensibilidad 7
3.7. Elaboración del modelo de amenazas (CIA) 8
4. Evidencias 9
5. Problemas encontrados y soluciones aplicadas 11
6.Riesgos pendientes 12

1. Resumen

Con este informe se pretende analizar la seguridad, diseño y despliegue de una gestion académica universitaria. Donde se desarrolla una base de datos en Docker y el modelo de amenzas.

2. Reparto del trabajo

Para la realizacion de este trabajo ha estado dividido según el peso del apartado, y por ello se ha dividido de la siguiente manera:

Sara: Modelo de entidad E-R y carga de datos

Nuria: Diseño del esquema de sql y modelo de amenazas

Yansul: Configuración y despliégue del entorno Docker

3. Desarrollo

3.1. Presentación del caso de negocio

Las entidades que consideramos necesarias para una buena base de daos de una universidad sería:

ENTIDAD	DESCRIPCIÓN	ATRIBUTOS
Departamento	Organiza los diferentes profesores	Id*depto(PK), nombre, id_profesor, email*_contacto
Profesor	Contiene los datos del profesor	Id*profesor (PK), id*departamento(FK), nombre, apellidos, email, asignaturas, clases
Titulación	Son los grados que imparte el centro	Id_titulación(PK), nivel, creditos, nombre, asignaturas
Asignatura	Las materias que forman una titulación	Id*asignatura(PK), id*titulación(FK), nombre, curso, creditos

Clase	Grupo de alumnos en una asignaura	Id*clase(PK), id*asignatura(FK), id_profesor(FK), curso, aula
Estudiante	Los datos de un alumno	Id*alumno(PK), nombre, apellido, email, cumpleaños, fechaalta,*
Calificación	Almacena las notas de los estudiantes y la convocatoria	Id*nota(PK), id*alumno(FK), id_asignatura(FK), nota, convocatoria
Activo	Indica si el alumno esta activo en el momento o si se dio de baja o matriculo	Id*activo(PK), id*alumno(FK), id*titulacion(FK), fecha*alta, fecha_baja, estado

Además, hay 4 tipos de usuario donde se encuentra el estudiante, profesor, personal administrativo y administrador.

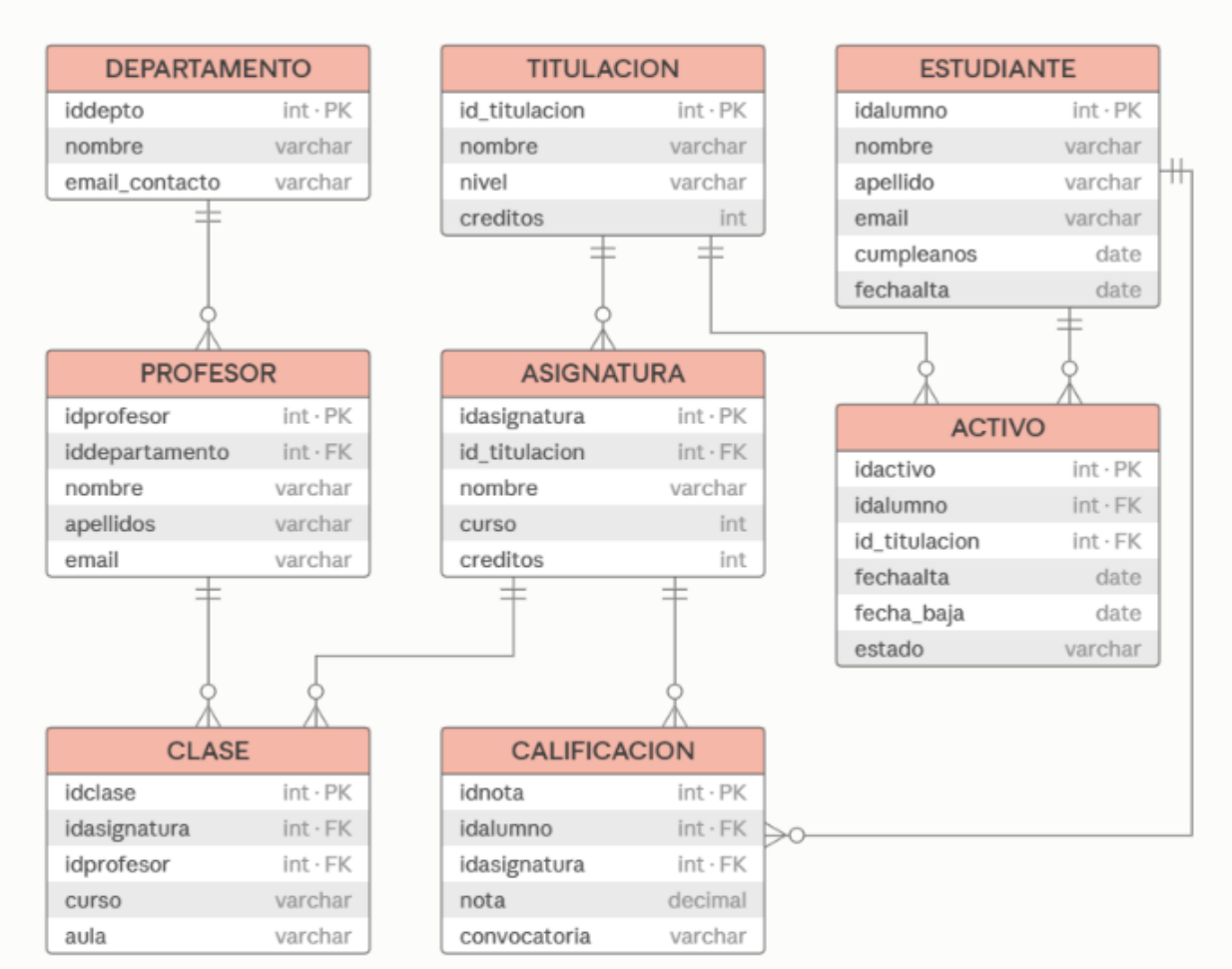
El estudiante tiene acceso restringido solamente a los datos que afectan a si mismo como las notas y datos personales. El profesor puede consultar sus asignaturas y calificaciones de los estudiantes. El personal administrativo son los que miran el estado de las cuentas de los estudiantes, si están activos y tienes las asignaturas correspondientes asignadas. Y finalmente estaría el administrador del sistema, el cual controla la infraestructura, copias de seguridad y permisos de los usuarios.

3.2. Diseño del modelo entidad-relación (E-R)

El modelo de entidad-relación, tendrá la siguiente cardinalidad:

RELACIÓN	CARDINALIDAD	EXPLICACIÓN
Departamento - Profesor	1:N	Un departamento puede tener varios profesores
Titulación - Asignatura	1:N	Una titilación está formada por diversas asignaturas
Asignatura - Clase	1:N	Una asignatura puede tener varios grupos de clase
Profesor - Clase	1:N	Un profesor puede dar varias clases
Estudiante - Calificación	1:N	Un estudiante obtiene diferentes notas

Estudiante - Activo	1:N	Un estudiante puede haber cursado diferentes titulaciones en la misma entidad universitaria



3.3. Creación del esquema de la base de datos MySQL

La base de dato se ha realizado en el entorno de MySQL 8 desplegado con Docker. Esto es debido a la compatabilidad de ellos.

El esquema esta formado con una estructura de 8 tablas (activo, asignatura, clase, calificacion , departamento, estudiante, profesor y titulación) en las cuales se almacena los datos cruciales para llevar un buen registro y con ello, tener una buena organizacion de los datos.

Para esta organizacion, es clave tener en cuenta algunas restricciones, donde se asignas claves primarias, para la relacion entre entidades, y que esta se incremente de forma automática, como el foreing y refences ; un número máximo de caracteres en los atributos varchar y que las fechas, sean en formato date.

3.4. Despliegue del entorno con Docker Compose

Para asegurar la portabilidad y la ejecución limpia del entorno, se ha desplegado mediante Docker Compose:

```
services:
  mysql:
    image: mysql:8.0
    environment:
      MYSQL_DATABASE: ${MYSQL_DATABASE}
      MYSQL_ROOT_PASSWORD: ${MYSQL_ROOT_PASSWORD}
      MYSQL_USER: ${MYSQL_USER}
      MYSQL_PASSWORD: ${MYSQL_PASSWORD}
    ports:
      - "3307:3306"
    volumes:
      - mysql_data:/var/lib/mysql

volumes:
  mysql_data:
```

3.5. Generación y carga de datos sintéticos

Para probar la base de datos hemos utilizado Python y la librería Faker para generar datos falsos de estudiantes y profesores.

El script generar_datos.py crea un archivo llamado datos_sinteticos.sql, que después hemos ejecutado en MySQL Workbench para introducir los datos en la base de datos gestion_academica.

El script de datos_ sinteticos.sql contiene:

- 5 departamentos universitarios.
- 25 profesores y 10 titulaciones.
- 40 asignaturas y 80 grupos de clase.
- 150 estudiantes registrados con sus estados de actividad.
- 320 calificaciones asociadas.
- 780 registros en total

3.6. Clasificación de los datos según el nivel de sensibilidad

Para poder clasificar los datos, hay que establecer algunos criterios de clasificación, para poder determinar las consecuencias que podría tener la divulgación pérdida o modificación de estos. Estos criterios son público, interno, confidencial y restringido.

A nivel público (Bajo) pueden estar los datos de los nombres de la titulaciones, creditos por asignatura, asignatuas, es decir, todas aquella que futuros estudiantes necesitan saber antes de apuntarse, para que consideren si es lo que estan buscando o no.

A nivel interno (Medio) estarían todos aquellos datos que sean procedimientos internos, documentacion operativa y técnica. Es decir, todo aquello que se tiene que limitar el acceso.

A nivel confidencial (Alto) serían todos los datos personales tanto de los empleados como de los estudiantes, es decir, datos de contacto, calificaciones, historial académico. En otras palabras, todos aquellos datos que se tiene que restringuir el acceso por el tipo de usuario y sus funciones.

Y finalmente, a nivel restringuido (Crítico), serías todas aquellas credenciales, claves, etc. Todo aquello que no se debe compartir bajo ningun concepto y que solo la persona involucrada deba saber.

A pesar de la clasificación, todos los daos deben tratarse de acuerso con la legislacion donde se tiene en cuenta la RGPD y LOPDGDD, además de la ENS.

3.7. Elaboración del modelo de amenazas (CIA)

Para elaborar el modelo de amenazas, se centra en la triada CIA, donde se analiza los activos tanto humanos como de infraestructura. Algunos de los ativos que nos podríamos encontrar en la entidad académica universitaria serían:

ID	ACTIVO	DESCRIPCIÓN	Amenaza	CIA	PROBABILIDAD	IMPACTO
A1	Base de datos	Almacenamiento de los datos de la gestión	Inyección SQL (SQLi) o exfiltración de registros de alumnos.	CIA	Media	Alto
A2	Copias de seguridad	Respaldos períodicos de la base de datos	Robo o acceso no autorizado a los dumps de respaldo	CA	Baja	Alto

			almacenados sin cifrar			
A3	Credenciales	Claves de acceso del personal y estudiantes	Ataques de fuerza bruta o filtración de hashes por contraseñas débiles.	C	Alta	Crítico
A4	Infraestructura física	Servidores, Docker, etc	Denegación de servicio (DDoS) o caída de recursos del servidor de BD.	A	Baja	Alto
A5	API / portal web	Interfaz de la gestión académica	Suplantación de identidad (Spoofing) por fallos en la validación de sesiones por rol.	CI	Baja	Alto
A6	Logs (registros de auditoria)	Registro de las acciones de los datos	Modificación fraudulenta de los datos	IA	Media	Alto

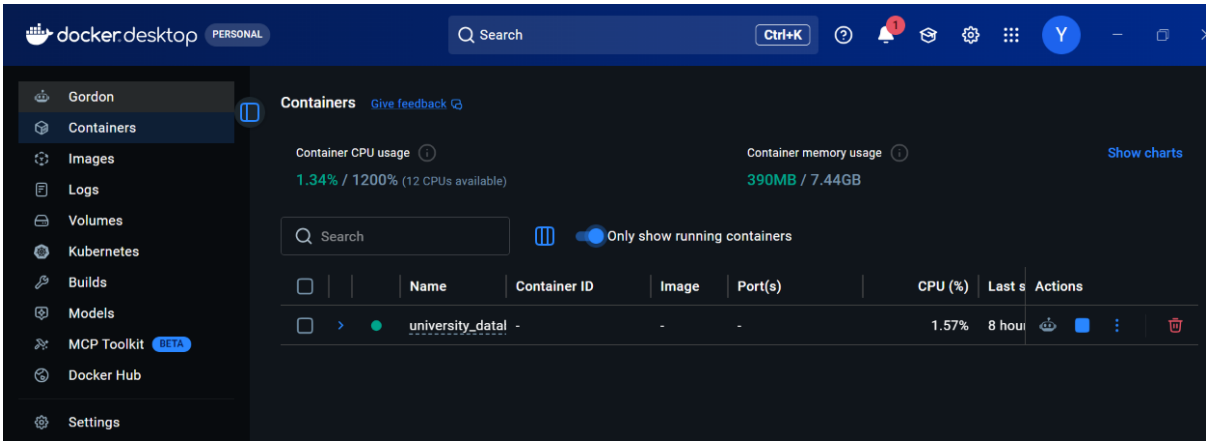
Medidas para reducir los riesgos altos y críticos

Para intentar evitar estos problemas, tendríamos que mejorar algunas cosas. Por ejemplo, en la base de datos (A1) usar consultas seguras para evitar ataques SQL. Las copias de seguridad (A2) deberían estar cifradas y, para las contraseñas (A3), podríamos poner una verificación en dos pasos.

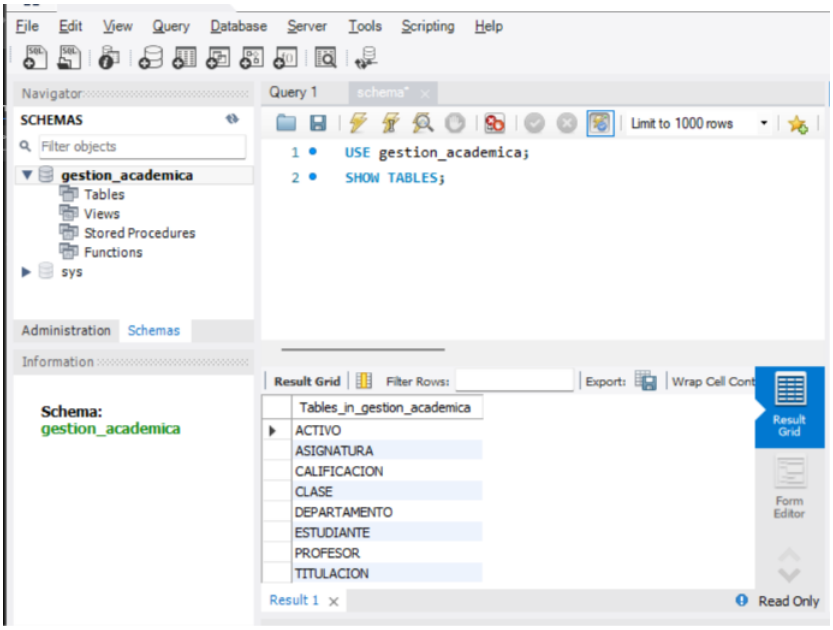
También sería importante revisar que los servidores funcionan bien (A4), que cada usuario solo pueda acceder a lo que le corresponde (A5) y que los registros no se puedan cambiar sin permiso (A6).

4. Evidencias

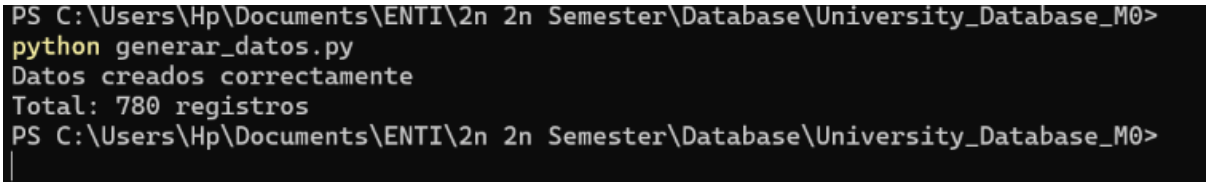
- Captura de la ejecución de docker-compose up -d y el contenedor en estado Running.



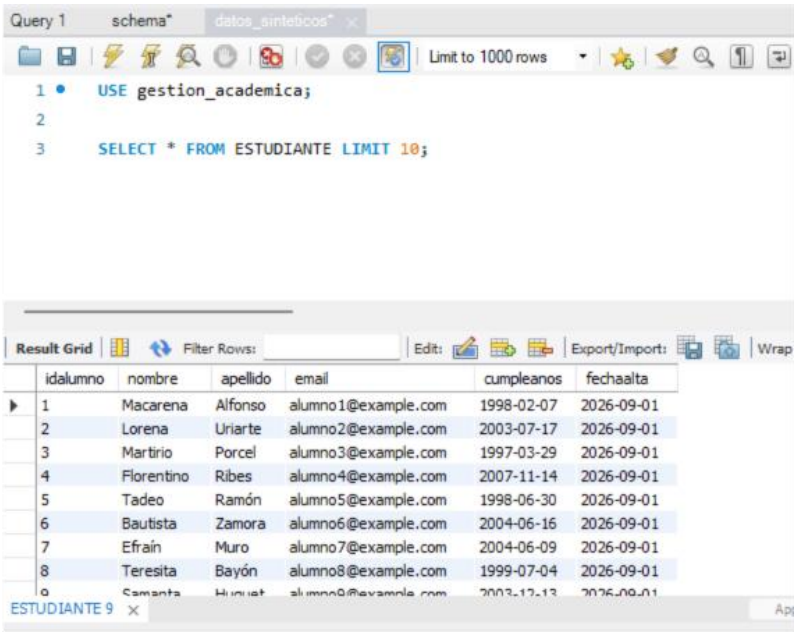
- Captura de la estructura de tablas en MySQL (SHOW TABLES;)



- Captura del script de Python/Faker generando los datos sintéticos.



- Captura del resultado de una consulta SELECT mostrando registros cargados en la base de datos.



5. Problemas encontrados y soluciones aplicadas

Algunos de los problemas que nos hemos encontrado a lo largo de este trabajo nos hemos encontrado los siguientes errores:

- Problema de orden en la carga de datos por dependencias de Claves Foráneas (FK):
  - Al intentar cargar el script de datos sintéticos, MySQL arrojaba errores de restricción de clave foránea.
  - *Solución:* Se ajustó el orden de inserción de datos (primero entidades independientes como Departamento, Titulación, Estudiante y posteriormente las dependientes como Profesor, Asignatura, Clase, Calificación, Activo). Alternativamente, se deshabilitaron temporalmente las verificaciones con SET FOREIGN_KEY_CHECKS=0;.
- Persistencia de datos en Docker:
  - Al reiniciar el contenedor de Docker, los datos se perdían.
  - *Solución:* Se configuró un volumen nombrado (mysql_data:/var/lib/mysql) en el archivo docker-compose.yml para garantizar la persistencia de la información en el host.
- Docker no funcionaba correctamente
  - Al principio no podíamos iniciar Docker porque faltaban algunas funciones de Windows necesarias para utilizarlo.
  - *Solución*: Activamos las funciones de Windows y configuramos WSL. Después reiniciamos el ordenador y Docker empezó a funcionar.
- Error de conexión con MySQL

- Al intentar conectarnos a MySQL desde Workbench, nos aparecía un error de acceso y no podíamos entrar en la base de datos.
- *Solución*: Revisamos el usuario, la contraseña y la configuración de la conexión hasta conseguir conectarnos correctamente.

6.Riesgos pendientes

Actualmente el sistema funciona, pero la mayor parte de la seguridad todavía está por hacer. Las credenciales del .env están en claro y pueden consultarse con docker inspect. Todo el acceso a la base de datos se hace con root o con un único usuario con demasiados privilegios, el puerto de MySQL está abierto en todas las interfaces y no existe ninguna política de contraseñas. Será necesario eliminar las cuentas por defecto, quitar el acceso remoto de root y evitar que las credenciales aparezcan en el código o en el repositorio.

Tampoco hay control de acceso por perfil: cualquier usuario puede ver todas las tablas, por lo que un estudiante podría consultar notas ajenas o un profesor modificar las de alumnos que no son suyos. La solución pasa por limitar el acceso mediante vistas y roles con mínimo privilegio, y por proteger con transacciones operaciones críticas como la matrícula o el cierre de actas, donde varias personas pueden modificar los mismos datos a la vez.

Los datos más sensibles, como el DNI, los datos bancarios de las becas o la salud, se guardan sin cifrar tanto en las columnas como en disco, por lo que una copia del volumen permitiría leerlo todo. Habrá que cifrar las columnas más delicadas, enmascararlas para los roles que no las necesitan y activar el cifrado en reposo. Cuando exista la aplicación, también habrá que almacenar las contraseñas con hash y salt, usar consultas parametrizadas contra la inyección SQL y cifrar la conexión con la base de datos.

Por último, no hay copias de seguridad ni registros de auditoría. Una pérdida del volumen de Docker sería irrecuperable y no se podría saber quién ha modificado una nota ni cuándo. Será necesaria una política de copias cifradas, con tiempos de recuperación pensados para los momentos críticos del curso. Los ataques de denegación de servicio, la seguridad física y el factor humano, como el phishing o la reutilización de contraseñas, quedan fuera del alcance del proyecto y se tratarán como recomendaciones.